

시큐어코딩



위협모델링 개요

01 위협모델링 개요

02 위협모델링 프로세스



학습 목표

- ✓ 위협모델링의 개념과 중요성을 이해한다.
- ✓ 위협모델링의 핵심 단계와 목적을 설명할 수 있다.
- ✓ 각 참여자의 역할과 협업 구조를 이해한다.
- ✓ MS-SDL에 기반한 위협모델링 프로세스를 파악한다.
- ✓ STRIDE, DREAD 등 주요 위협모델링 프레임워크의 특징을 설명할 수 있다.



학습 내용

1. 위협모델링의 정의와 핵심 개념
2. 위협모델링의 필요성과 기대 효과
3. 역할별 위협모델링 참여 구조
4. STRIDE, DREAD 등 프레임워크 소개
5. MS-SDL 위협모델링 프로세스 및 단계별 활동



위협모델링 개요

01 위협모델링 개요

02 위협모델링 프로세스

위협모델링(Threat Modeling)이란?

위협 모델링(Threat Modeling)은 소프트웨어, 시스템 또는 네트워크의 보안 취약점을 사전에 식별하고, 이를 평가하여 적절한 보안 대책을 수립하는 과정

주요 개념

- 사전 예방적 보안 접근법: 설계 단계에서 보안 위협을 예측하고 방어책을 마련하는 방식.
- 공격자 관점의 분석: 공격자가 시스템을 어떻게 악용할 수 있는지를 분석하여, 보안 취약점을 최소화.
- 개발 프로세스 내 통합: 보안이 개발 과정(SDLC)에서 자연스럽게 반영될 수 있도록 구조화된 방법론 적용.

위협 모델링은 설계 단계부터 보안을 고려하고, 실질적인 공격 시나리오를 예측하여 사전 대응할 수 있는 강력한 방법론

위협모델링(Threat Modeling)의 핵심 목표

위협 모델링의 핵심 목표

1. 시스템 이해: 보호해야 할 자산(데이터, 기능 등)과 이를 둘러싼 환경을 분석.
2. 위협 식별: 해커나 내부 공격자가 악용할 수 있는 취약점을 분석.
3. 위협 평가: 위협의 심각도와 발생 가능성을 평가하여 대응 우선순위를 설정.
4. 보안 조치 적용: 위협을 완화할 수 있는 설계 및 보안 제어(암호화, 접근제어 등) 적용.

위협모델링(Threat Modeling)이 중요한 이유

위협 모델링이 중요한 이유

1. 사전 보안 강화: 개발 초기 단계에서 보안을 고려하여, 비용을 절감하고 보안성을 높일 수 있음.
2. 보안 사고 예방: 공격자의 시각에서 보안 취약점을 분석하여 예상되는 보안 사고를 방지.
3. 법규 및 표준 준수: 금융, 의료 등 특정 산업에서는 보안 규정을 준수하기 위한 필수 절차.
4. DevSecOps 연계: 보안이 지속적으로 개발 및 운영 과정에서 반영될 수 있도록 지원.

위협모델링(Threat Modeling) 참가자 및 역할

직무명	개발팀 (Developers)	보안 전문가 (Security Engineers / Security Architects)	시스템 아키텍트 (System Architects)
역할	시스템의 구조를 이해하고, 보안 요구사항을 코드에 반영.	보안 위협을 식별하고, 취약점 분석 및 대응책 수립.	시스템의 설계를 담당하며, 보안이 고려된 설계 구조를 반영.
참여이유	애플리케이션의 동작 방식과 기술적 구현을 가장 잘 이해. 보안 취약점이 발생할 가능성이 높은 코드 영역을 식별. 위협 모델링 과정에서 제안된 보안 개선 사항을 직접 구현.	공격자의 관점에서 보안 위협을 예측하고, 효과적인 방어 전략을 제안. 최신 보안 위협 동향 및 취약점 정보를 제공. 위협 모델링 프레임워크 (예: STRIDE, DREAD)를 적용하여 체계적인 분석 수행.	애플리케이션 및 인프라의 전반적인 구조를 설계하는 역할. 보안 요구사항을 고려하여 아키텍처를 조정하고 강화. 위협 모델링을 기반으로 보안 설계 원칙을 적용.

위협모델링(Threat Modeling) 참가자 및 역할

직무명	제품 관리자 (Product Owners / Project Managers)	운영팀 (DevOps / IT Operations)	품질보증(QA) 및 테스터 (QA Engineers / Penetration Testers)
역할	보안 요구사항을 개발 프로세스에 반영하고, 프로젝트 일정 관리.	배포된 애플리케이션의 보안 운영 및 지속적인 모니터링 수행.	보안 테스트 및 취약점 점검을 통해 위협 모델링 검증.
참여이유	보안 요구사항이 제품 기능에 미치는 영향을 조율. 보안과 비즈니스 요구사항 간의 균형을 맞추어 의사결정. 위협 모델링 결과를 제품 개발 라이프사이클에 반영.	배포 및 운영 환경에서 발생할 수 있는 보안 위협을 파악. 보안 로그 및 모니터링 데이터를 분석하여 위협 모델링 결과를 보완. DevSecOps 환경에서 자동화된 보안 점검 및 대응 전략을 마련.	위협 모델링에서 정의한 위협 시나리오를 기반으로 보안 테스트 수행. 침투 테스트(Penetration Testing)를 통해 실제 공격 가능성을 평가. 보안 검증을 통해 위협 모델링에서 도출된 보안 요구사항이 충족되었는지 확인.

위협모델링(Threat Modeling) 흐름

단계	주요내용
워크숍 진행 (Threat Modeling Workshops)	개발자, 보안 전문가, 아키텍트 등이 함께 위협 모델링을 수행하는 세션 진행. 시스템 다이어그램(DFD, Sequence Diagram 등)을 기반으로 위협 분석.
위협 분석 및 평가	STRIDE, DREAD, PASTA 등 위협 모델링 기법을 적용하여 위협 분석. 참가자들이 위협의 심각도를 평가하고 대응 우선순위 결정.
보안 설계 개선 및 구현	개발팀이 보안 요구사항을 코드에 반영. 운영팀이 보안 모니터링 및 대응 체계를 구축.

위협모델링(Threat Modeling) 프레임워크

위협 모델링 프레임워크는 소프트웨어, 시스템, 네트워크 등의 보안 위협을 체계적으로 식별하고 분석하는 방법론이다. 프레임워크마다 적용 방식이 다르며, 특정 환경과 목적에 따라 적절한 프레임워크를 선택해야 한다.

대표적인 위협모델링 프레임워크

프레임워크	주요 특징	적용 분야
STRIDE★	가장 널리 사용되는 위협모델링 기법으로 6가지 보안 위협 유형 정의	애플리케이션 보안, MS-SDL, 클라우드보안
PASTA	공격자의 관점에서 위협을 분석하고 비즈니스 영향도 평가	금융, 의료, 대규모 엔터프라이즈 시스템
DREAD★	위협을 정량적으로 평가하는 모델, 위험도를 수치화 하여 우선순위 결정	침투테스트, 보안 리스크 평가
Attack Tree	공격 목표를 중심으로 다양한 공격 경로를 시각적으로 표현	IoT, 산업제어시스템(ICS), 네트워크 보안
OCTAVE	조직의 전반적인 보안 위협을 평가하고 거버넌스 중심으로 분석	기업보안, IT리스크 관리

위협모델링 프레임워크 - STRIDE

STRIDE는 Microsoft에서 개발한 가장 널리 사용되는 위협 모델링 프레임워크로, 6가지 보안 위협 유형을 정의한다.

* 주요 위협 요소

위협 유형	설명	보안대응책
S poofing (신원 위조)	공격자가 허가 없이 시스템에 허가된 사용자로 가장	강력한 인증(MFA, OAuth) 적용
T ampering (데이터 변조)	데이터가 불법적으로 변경되거나 조작됨	무결성 검사(Hash, 디지털 서명)
R epudiation (부인)	공격자가 악의적인 행동을 부인 가능	로그 및 감사를 통한 책임 추적(Audit Logs)
I nformation Disclosure (정보 노출)	기밀 데이터가 외부에 노출됨	데이터 암호화(AES, TLS, SSL)
D enial of Service (서비스 거부)	시스템을 사용할 수 없도록 하는 공격	트래픽 제한, WAF, DDoS 보호
E levation of Privilege (권한 상승)	공격자가 권한을 상승하여 관리자 권한 획득	최소 권한 원칙, 권한 검증 강화

위협모델링 프레임워크 - DREAD

DREAD는 위협을 정량적으로 평가하여 리스크의 심각도를 수치화하는 모델. 각 항목을 0~10점으로 평가하고 합산하여 위험 순위를 설정한다.

항목	설명
D amage (피해 규모)	시스템이 공격을 받을 경우의 피해 정도
R eproducibility (재현 가능성)	공격이 얼마나 쉽게 재현될 수 있는지
E xploitability (공격 가능성)	공격을 수행하기 얼마나 쉬운지
A ffected Users (영향 받는 사용자 수)	공격으로 인해 영향을 받는 사용자 수
D iscoverability (발견 가능성)	공격자가 취약점을 얼마나 쉽게 찾을 수 있는지

위협모델링 프레임워크 - DREAD 세부 점수 기준 예시

점수	Damage	Reproducibility	Exploitability	Affected Users	Discoverability
0점	전혀 피해 없음	공격 재현 불가능	공격이 불가능함	특정 내부 테스트 사용자만 영향	비공개 코드로 공격자가 알기 어려움
2~3점	일부 기능 오류 발생	매우 특수한 조건에서만 재현 가능	고급 공격 기술이 필요함	일부 내부 사용자 영향	전문 보안 연구자가 분석해야 찾을 수 있음
5점	서비스 성능 저하, 데이터 무결성 손상 가능	특정 조건을 충족하면 재현 가능	일반적인 보안 전문가가 공격 가능	일부 외부 사용자 영향	OWASP Top 10 수준의 일반적인 취약점
7~8점	주요 기능 장애, 데이터 유출 위험	거의 모든 환경에서 재현 가능	기본적인 해킹 지식만 있어도 가능	광범위한 사용자에게 영향	자동화된 도구 (Nmap, Metasploit)로 쉽게 탐지 가능
10점	시스템 전체 다운, 기밀 데이터 유출	언제든지 쉽게 재현 가능	누구나 몇 초 만에 공격 가능	모든 사용자 및 전체 네트워크 영향	구글 검색, 일반 사용자도 취약점 발견 가능

예시는 극단적인 값과 중간값으로 설정한 점수 모델. 실무에서는 세부적인 차이를 반영하기 위해 4,6,9점 도 정의해서 사용할 수 있음.

위협모델링 프레임워크 - DREAD 총점 기준에 따른 위협 수준

총점 (D+R+E+A+D)	위협 수준	대응 우선 순위
0~10점	낮음 (Low)	모니터링 필요하지만 즉각 조치는 필요 없음
11~20점	보통 (Medium)	보안 패치 적용 고려, 필요 시 수정
21~30점	높음 (High)	보안 조치 필수, 공격 가능성이 높음
31~50점	치명적 (Critical)	즉시 대응 필요, 긴급 패치 또는 보안 조치 시행

위협모델링 프레임워크 - DREAD 평가 예시

예시: 약한 비밀번호 정책 (ex: 4자리 숫자 비밀번호)

평가 항목	점수	설명
D amage	5	비밀번호 유출 시 계정 탈취 가능하지만 전체 시스템은 영향 없음
R eproducibility	10	누구나 여러 번 시도하여 쉽게 비밀번호를 크랙할 수 있음
E xploitability	10	간단한 스크립트 또는 도구로 공격 가능
A ffected Users	8	많은 사용자가 영향을 받을 가능성이 있음
D iscoverability	10	자동화된 도구(Brute-force 공격)로 쉽게 탐지 가능
총점	42(Critical)	긴급 패치 필요 (MFA 적용, 복잡한 비밀번호 요구)



위협모델링 개요

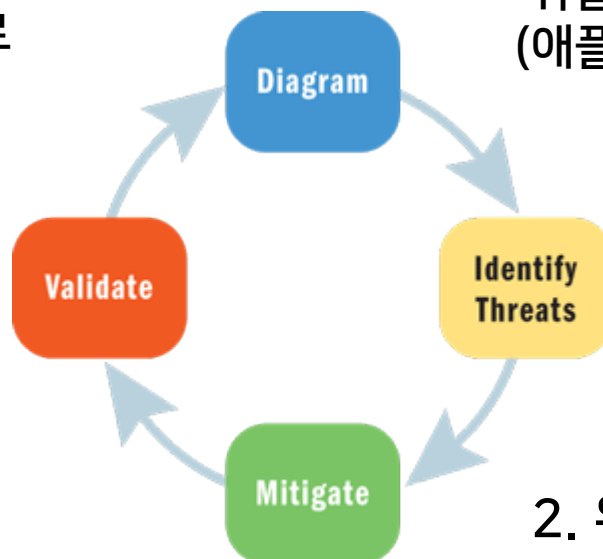
01 위협모델링 개요

02 위협모델링 프로세스

위협모델링 프로세스

4. 검토 및 개선(Validate & Review)
위협모델링 결과를 검토하고 지속적으로
개선하여 보안성을 강화

3. 완화 계획 수립(Mitigate Threats)
식별된 위협을 해결하기 위해 보안 조치를
설계하고 구현



위협모델링 프로세스

1. 시스템 정의(Define the System)
위협 모델링을 수행하기 위해 보호할 대상
(애플리케이션, 데이터, 시스템 등)을 명확히 정의

2. 위협 식별(Identify Threats)
STRIDE 기법을 사용하여 시스템에서 발생할
수 있는 잠재적인 위협을 식별

위협모델링 프로세스 - 시스템 정의(Define the System)

Diagram

 목표: 위협 모델링을 수행하기 위해 보호할 대상(애플리케이션, 데이터, 시스템 등)을 명확히 정의

✓ 주요 활동:

- 시스템의 아키텍처 및 구성 요소 파악
- 데이터 흐름 다이어그램(DFD) 작성
- 신뢰 경계(Trust Boundaries) 설정
- 보호해야 할 주요 자산(데이터, 기능 등) 식별

✂ 활용 기법:

- DFD(Data Flow Diagram): 데이터의 이동 경로를 시각적으로 표현
- 아키텍처 다이어그램: 시스템의 주요 구성 요소와 관계를 도식화

위협모델링 프로세스 - 위협 식별(Identify Threats)

Identify Threats

🎯 목표: STRIDE 기법을 사용하여 시스템에서 발생할 수 있는 잠재적인 위협을 식별

✅ 주요 활동:

- STRIDE 기반의 위협 시나리오 분석
- 시스템 내 취약점을 공격자의 관점에서 분석
- 위협 목록 작성 및 우선순위 지정

✂ 활용 기법:

· STRIDE모델(Microsoft)

- | | | |
|----------------------------------|---|--------------------------|
| - Spoofing (신원 위조) | → | 인증(Authentication) 위협 |
| - Tampering (데이터 변조) | → | 무결성(Integrity) 위협 |
| - Repudiation (부인 방지 실패) | → | 감사(Audit) 위협 |
| - Information Disclosure (정보 노출) | → | 기밀성(Confidentiality) 위협 |
| - Denial of Service (서비스 거부) | → | 가용성(Availability) 위협 |
| - Elevation of Privilege (권한 상승) | → | 접근 제어(Access Control) 위협 |

· 위협 분석 기법

- 공격 트리(Attack Tree) 작성
- 위협 시나리오 및 공격 경로 분석
- OWASP Top 10 및 CVE 취약점 참고

위협모델링 프로세스 - 완화 계획 수립(Mitigate Threats)

Mitigate

 목표: 식별된 위협을 해결하기 위해 보안 조치를 설계하고 구현

✓ 주요 활동:

- 위협별 완화 전략 수립 및 적용
- 보안 코딩 원칙 적용
- 접근 제어 강화 및 암호화 적용
- 보안 테스트 계획 수립

✳ 활용 기법:

- ◆ 보안 설계 원칙 적용
 - 최소 권한 원칙(Least Privilege)
 - 보안 강화된 기본 설정(Secure Defaults)
 - 방어적 코딩(Defensive Coding)
- ◆ 보안 기술 적용
 - 안전한 인증 및 암호화 기법 적용 (예: MFA, AES 암호화)
 - 입력 검증(Input Validation) 및 보안 필터링 적용
 - 보안 로깅 및 감사를 위한 모니터링 도구 활용
- ◆ 보안 테스트
 - 정적 분석(SAST), 동적 분석(DAST) 도구 적용
 - 침투 테스트 수행

위협모델링 프로세스 - 검토 및 개선(Validate & Review)

Validate

 목표: 위협 모델링 결과를 검토하고, 지속적으로 개선하여 보안성을 강화

✓ 주요 활동:

- 위협 모델 검토 및 보안 점검
- 보안 조치의 효과성 검증
- 새롭게 발견된 위협에 대한 업데이트 수행

✂ 활용 기법:

- ◆ 보안 검토(Threat Model Review) 수행
 - 위협 모델이 최신 시스템 아키텍처를 반영하는지 검토
 - 보안 취약점이 해결되었는지 확인
- ◆ 지속적인 개선 및 업데이트
 - DevSecOps 환경에서 자동화된 보안 점검 도입
 - 최신 위협 정보를 반영하여 보안 정책 업데이트

MS-SDL 위협모델링 프로세스 요약

단계	주요활동	활용기법
1. 시스템 정의	보호할 자산 및 데이터 흐름 분석	DFD, 아키텍처 다이어그램
2. 위협 식별	STRIDE 모델을 활용하여 보안 위협 분석	STRIDE, 공격트리, OWASP TOP 10
3. 완화 계획 수립	위협별 보안 조치 적용	최소 권한 원칙, 암호화, 접근제어, 보안코딩
4. 검토 및 개선	보안 검토 및 지속적인 업데이트 수행	정적 분석, 동적 분석, 보안 테스트

MS-SDL 위협 모델링의 특징

- ✓ 개발 초기(설계 단계)에서 보안 위협을 사전에 분석
- ✓ STRIDE 모델을 활용하여 체계적으로 위협을 식별
- ✓ 보안 요구사항을 개발 프로세스에 반영하여 자동화 가능
- ✓ DevSecOps와 연계하여 지속적인 보안 검증 및 개선 가능

MS-SDL의 위협 모델링은 보안이 내재화된 개발 프로세스를 구축하는 데 핵심적인 역할을 한다.



요약 정리

- ✓ 위협모델링은 보안 위협을 사전에 식별하고 대응하기 위한 구조화된 분석 기법이다.
- ✓ 위협모델링은 설계 단계에서 보안을 내재화하고, 공격자의 관점에서 위협을 분석한다.
- ✓ 위협모델링의 핵심 목표는 시스템 이해, 위협 식별, 위협 평가, 보안 조치 적용이다.
- ✓ 다양한 직무의 참여자가 협업하여 위협모델링을 수행하고, 역할에 따라 보안 요구사항을 반영한다.
- ✓ 대표적인 프레임워크로는 STRIDE, DREAD, PASTA, Attack Tree 등이 있다.
- ✓ MS-SDL 위협모델링을 소프트웨어 개발 생명주기에 통합하여 보안 사고를 예방한다.



참고 문헌

- [KISA] 소프트웨어 개발 보안 가이드(2021.12.29)
- [KISA] 소프트웨어 보안약점 진단가이드(2021)
- [에이콘출판사] 보안 위협 모델링 Threat Modeling - 위협 식별과 대응을 위한 소프트웨어 설계
- [책만] 모두를 위한 소프트웨어 보안 설계와 구현 - 취약점 분석부터 위협 모델링과 완화 전략, 보안 패턴, 암호화까지 안전한 소프트웨어의 모든 것
- [WILEY] Threat Modeling: Designing for Security - Adam Shostack
- [OREILLY] Threat Modeling: A Practical Guide for Development Teams - Izar Tarandach, Matthew Coles
- [WILEY] Security Engineering - Ross J. Anderson (Chapter 23 Threat Modeling)
- Threat Modeling manifesto - <https://www.threatmodelingmanifesto.org/>
- OWASP Threat Modeling Project - https://owasp.org/www-community/Threat_Modeling

The background is a vibrant blue gradient. It is decorated with various abstract elements: a large solid blue sphere in the upper left, a smaller sphere with diagonal stripes in the upper right, and another striped sphere in the lower left. Several network diagrams, consisting of white dots connected by thin white lines, are scattered across the image. There are also solid blue rectangular bars of different sizes and orientations. The overall aesthetic is modern and technological.

감사합니다.



퀴즈

1. 다음 중 위협모델링의 핵심 목표가 아닌 것은?

- 1) 위험 평가
- 2) 보안 조치 적용
- 3) 시스템 이해
- 4) SW 구조 이해

2. 다음 중 위협모델링 프로세스 단계에 대한 내용이 틀린 것은?

- 1) 시스템 정의 - 구성원간 상호 협업 시스템을 명확히 정의
- 2) 위협 식별 - 발생할 수 있는 잠재적 위협을 식별
- 3) 완화 계획 수립 - 보안조치를 설계하고 구현
- 4) 검토 및 개선 - 결과를 검토하고 지속적으로 개선

3. 다음 중 STRIDE 프레임워크에서 정의한 주요 위협요소에 대한 설명으로 올바른 것은?

- 1) 신원 위조 - 사용자가 악의적인 행동을 부인 가능
- 2) 권한 상승 - 기밀 데이터가 외부에 노출
- 3) 서비스 거부 - 시스템을 사용할 수 없도록 하는 공격
- 4) 정보 노출 - 데이터가 불법적으로 변경되거나 조작됨



퀴즈 정답

1. 다음 중 위협모델링의 핵심 목표가 아닌 것은?

4) SW 구조 이해

위협 모델링의 핵심 목표는 시스템 이해, 위협 식별, 위협 평가, 보안 조치 적용입니다.

2. 다음 중 위협모델링 프로세스 단계에 대한 내용이 틀린 것은?

1) 시스템 정의 - 구성원간 상호 협업 시스템을 명확히 정의

시스템 정의 단계에서는 위협 모델링을 수행하기 위해 보호할 대상을 명확히 정의하게 됩니다.

3. 다음 중 STRIDE 프레임워크에서 정의한 주요 위협요소에 대한 설명으로 올바른 것은?

3) 서비스 거부 - 시스템을 사용할 수 없도록 하는 공격

서비스 거부 보안 위협은 트래픽 제한, WAF 도입, DDoS 보호 서비스 적용 등으로 대응책을 마련할 수 있습니다.